

INFORME EJECUTIVO Y TÉCNICO DE PENTESTING



Evaluación de Seguridad Ofensiva, Hackeo Ético
y Verificación OWASP ASVS v4.0.3

 Índice / Tabla de Contenidos

1. Resumen Ejecutivo y Ficha Técnica	Pág. 3
2. Metodología de Evaluación y Estándares Aplicados	Pág. 4
2.1 Marcos Normativos Utilizados	Pág. 4
2.2 Escala de Severidad y Prioridad	Pág. 4
3. Métricas y Distribución Estadísticas de Hallazgos	Pág. 5
Gráficos de Distribución (Barras — Estado del Ticket)	Pág. 6
Gráficos de Distribución (Torta — Severidad)	Pág. 7
4. Alcance Técnico y Componentes Evaluados	Pág. 8
5. Detalle de Vulnerabilidades e Incidencias Registradas	Pág. 9
Prueba de Concepto (PoC) paso a paso	Pág. 10
Evidencias Fotográficas (Capturas de Pantalla)	Pág. 11
6. Conclusiones y Plan de Remediación Recomendado	Pág. 12

1. Resumen Ejecutivo y Ficha Técnica

Durante la evaluación del sistema de turnos médicos «Turnero» se identificó una falla crítica de control de acceso que permite a cualquier usuario autenticado consultar y eliminar los turnos médicos de otros pacientes, sin validación de pertenencia.

Un usuario malicioso con una cuenta común podría cancelar turnos ajenos a voluntad, afectando la operatoria del centro de salud y la confianza de los pacientes. Severidad: ALTA (CVSS 8.3). Se recomienda remediar antes de pasar a producción.

Parámetro / Campo	Detalle de la Evaluación
Tipo de Evaluación	Penetration Testing (Caja Gris) — Sistema de Turnos Médicos
Estándar Principal	OWASP ASVS 4.0.3 (Level 2/3) & OWASP Top 10
Período de Pruebas	Octubre 2026 — Laboratorio de práctica (Módulo de Pentesting)
Entorno de Evaluación	Ambiente de Laboratorio — Aplicación «Turnero»
Clasificación del Documento	ESTRICTAMENTE CONFIDENCIAL

2. Metodología de Evaluación y Estándares Aplicados

Las pruebas se ejecutaron combinando análisis estático (SAST), análisis dinámico (DAST) y pruebas de penetración manuales profundas, para reducir falsos positivos y garantizar la exhaustividad del análisis.

2.1 Marcos Normativos Utilizados

OWASP ASVS v4.0.3

Verificación estructurada de controles de seguridad en arquitectura, autenticación, control de acceso y criptografía.

OWASP Top 10

Clasificación de las vulnerabilidades web más críticas: inyecciones, fallos de control de acceso, criptografía deficiente, entre otras.

PTES — Penetration Testing Execution Standard

Guía de fases del pentest: reconocimiento, descubrimiento, explotación y post-explotación.

2.2 Escala de Severidad y Prioridad (CVSS v3.1)

Los hallazgos se evalúan bajo la matriz CVSS v3.1, clasificándose en cuatro niveles:

CRÍTICA · 9.0–10.0

Ejecución remota de código o acceso total al sistema sin autenticación.

ALTA · 7.0–8.9

Compromiso grave de confidencialidad o integridad con impacto sustancial.

MEDIA · 4.0–6.9

Fallos de lógica o bypass de controles que requieren condiciones previas.

BAJA · 0.1–3.9

Revelación menor de información técnica o configuraciones no óptimas.

3. Métricas y Distribución Estadística de Hallazgos

A continuación se consolidan las métricas del estado actual de los hallazgos registrados durante la auditoría de ejemplo (laboratorio Turnero — Control de Acceso / IDOR).

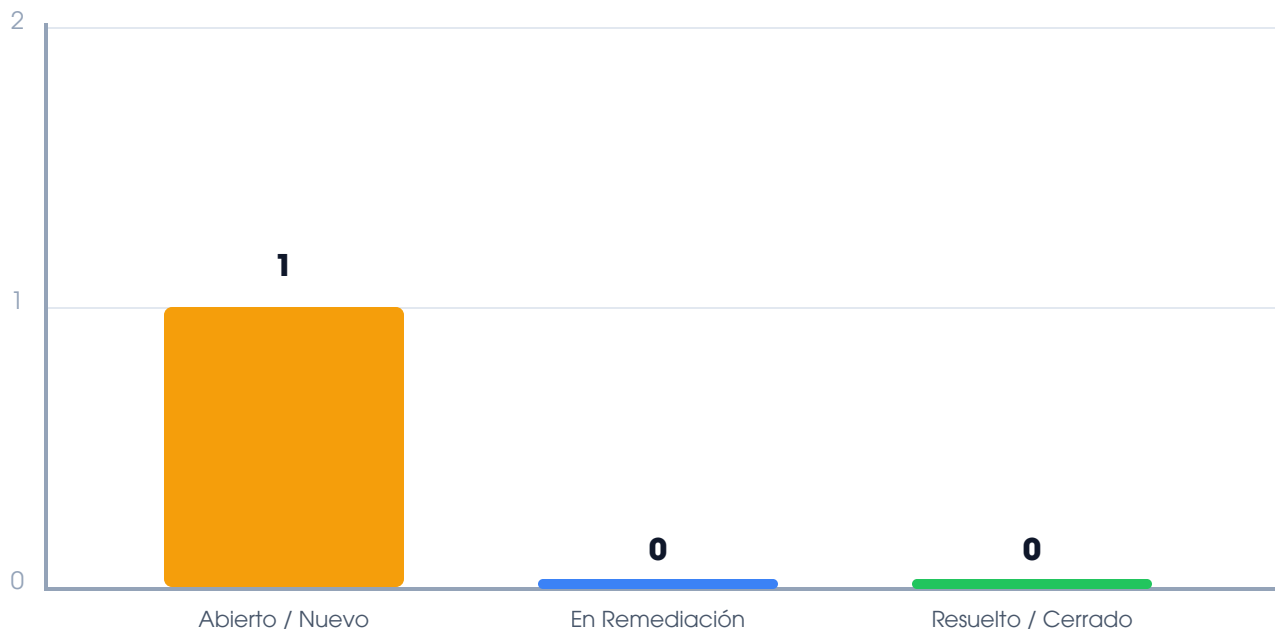


Distribución por estado del ticket

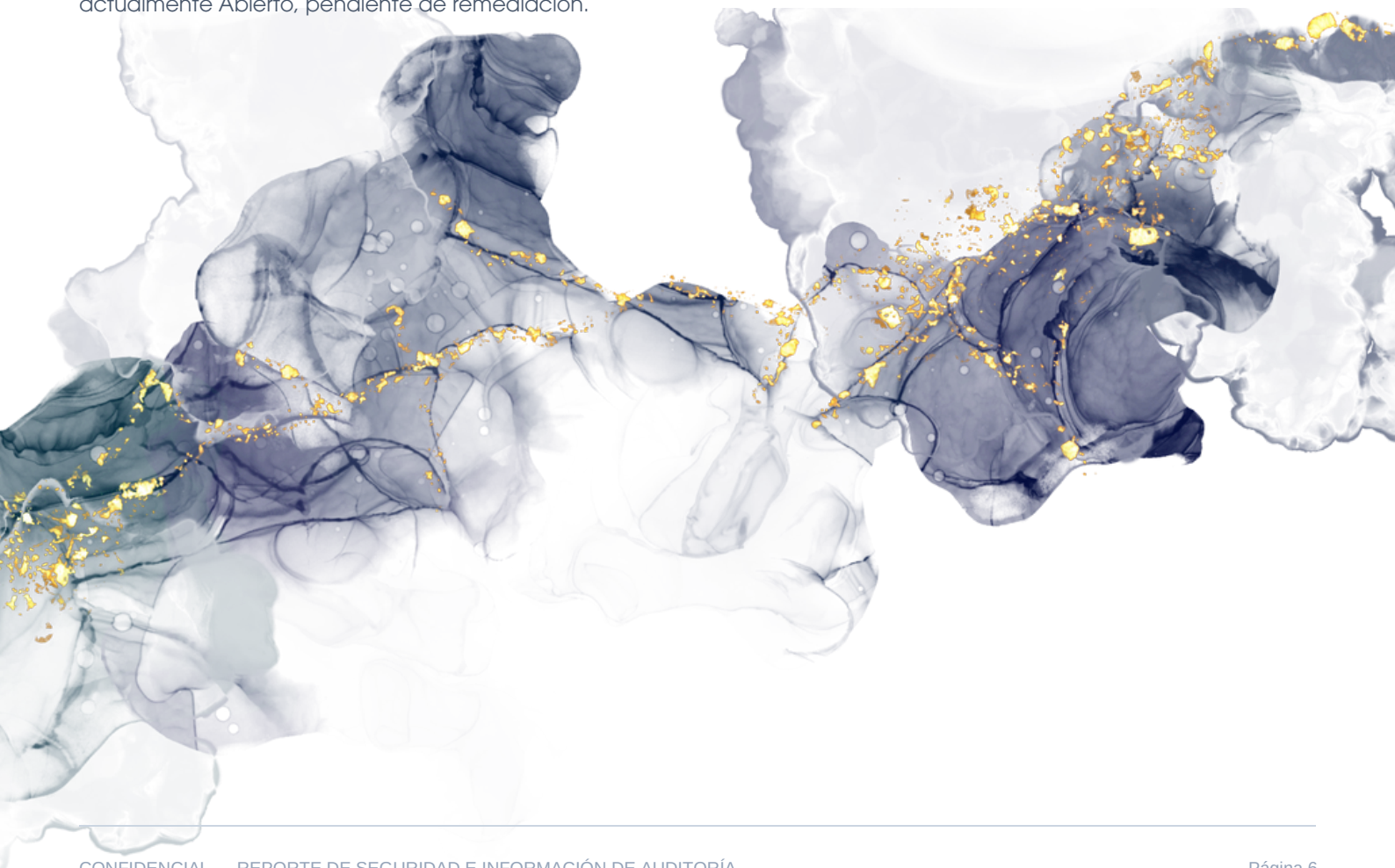
Estado del hallazgo	Cantidad	Porcentaje
Abierto / Nuevo	1	100%
En Remediación	0	0%
Resuelto / Cerrado	0	0%
Total	1	100%

Distribución por Estado del Ticket

El gráfico de barras muestra cómo se reparten los hallazgos según su estado de gestión al cierre de la auditoría.

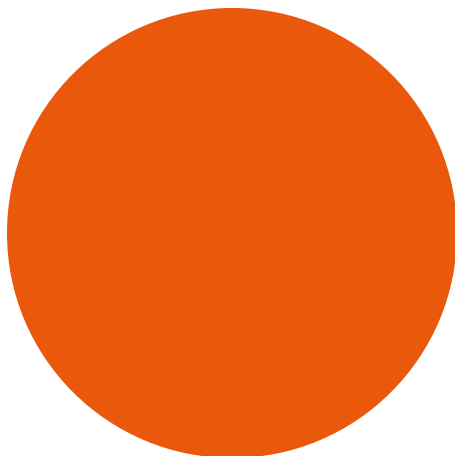


Cada barra representa la cantidad de hallazgos en ese estado. El único hallazgo de esta auditoría se encuentra actualmente Abierto, pendiente de remediación.



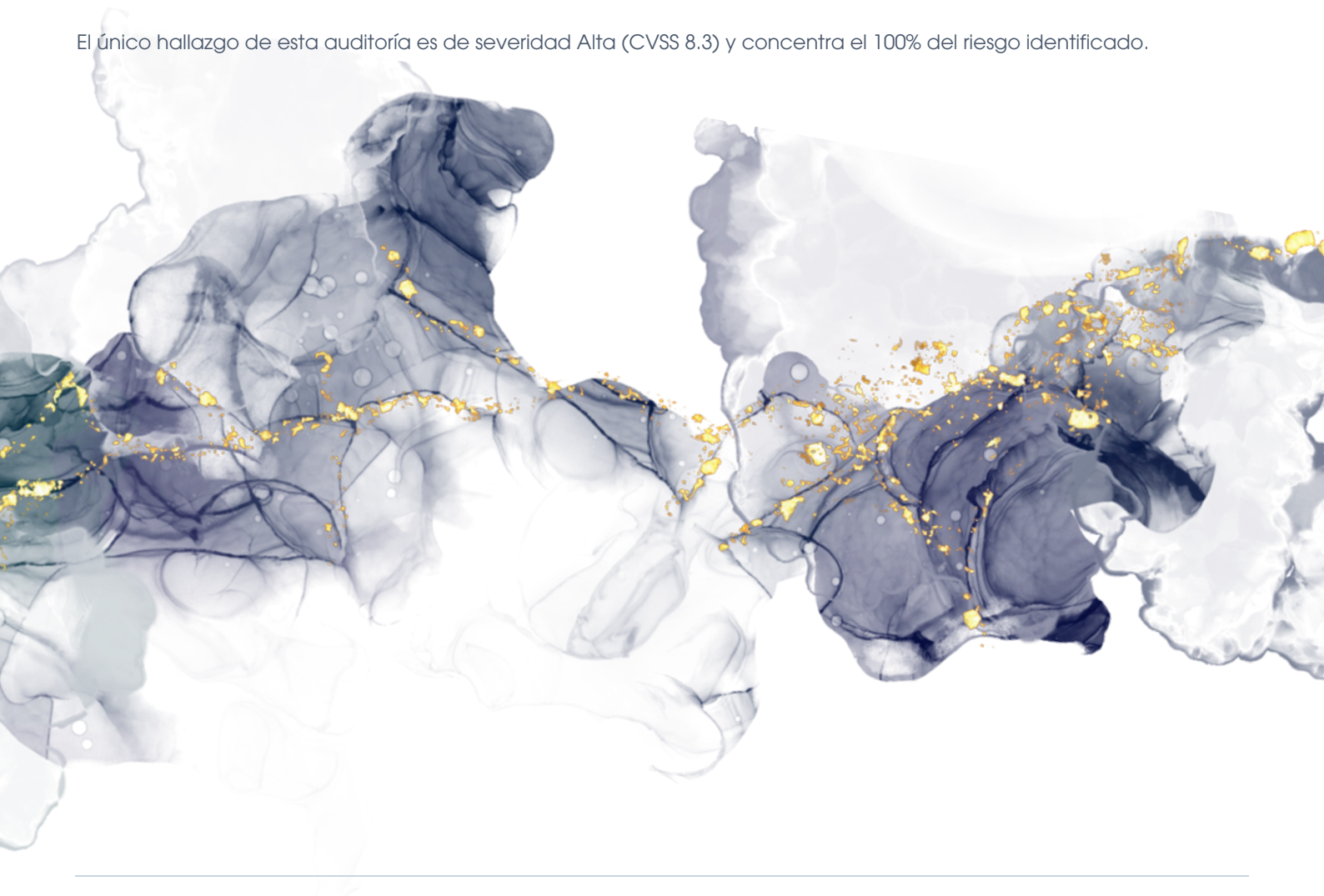
Distribución por Severidad

La torta muestra la proporción de hallazgos según su nivel de severidad CVSS.



Alta — 1 hallazgo (100%)

El único hallazgo de esta auditoría es de severidad Alta (CVSS 8.3) y concentra el 100% del riesgo identificado.



4. Alcance Técnico y Componentes Evaluados

Esta auditoría puntual se centró en un único vector de ataque. A continuación se detalla qué se evaluó y qué quedó fuera de alcance:

Autenticación y Gestión de Sesiones — Fuera de alcance

No se evaluó en esta auditoría puntual: el foco fue exclusivamente el vector de control de acceso descrito abajo.

Control de Acceso e Impersonación — Único vector evaluado

Elevación de privilegios horizontal (IDOR) en los endpoints de lectura y borrado de turnos — es el hallazgo VULN-001 detallado en la sección 5.

Validación de Entradas y Sanitización — Fuera de alcance

No se probaron inyecciones (SQLi, XSS, Command Injection, SSRF) en esta auditoría puntual.

Seguridad en Comunicaciones y Criptografía — Fuera de alcance

No se evaluó cifrado en tránsito/reposo ni algoritmos utilizados en esta auditoría puntual.

Manejo de Errores y Registro de Eventos — Fuera de alcance

No se revisaron trazas de pila ni logs de auditoría en esta auditoría puntual.

5. Detalle de Vulnerabilidades e Incidencias Registradas

Se detalla el hallazgo principal identificado, con su descripción técnica, clasificación normativa y desglose de severidad CVSS.

VULN-001 · IDOR — Acceso y borrado de turnos ajenos

ALTA · CVSS 8.3

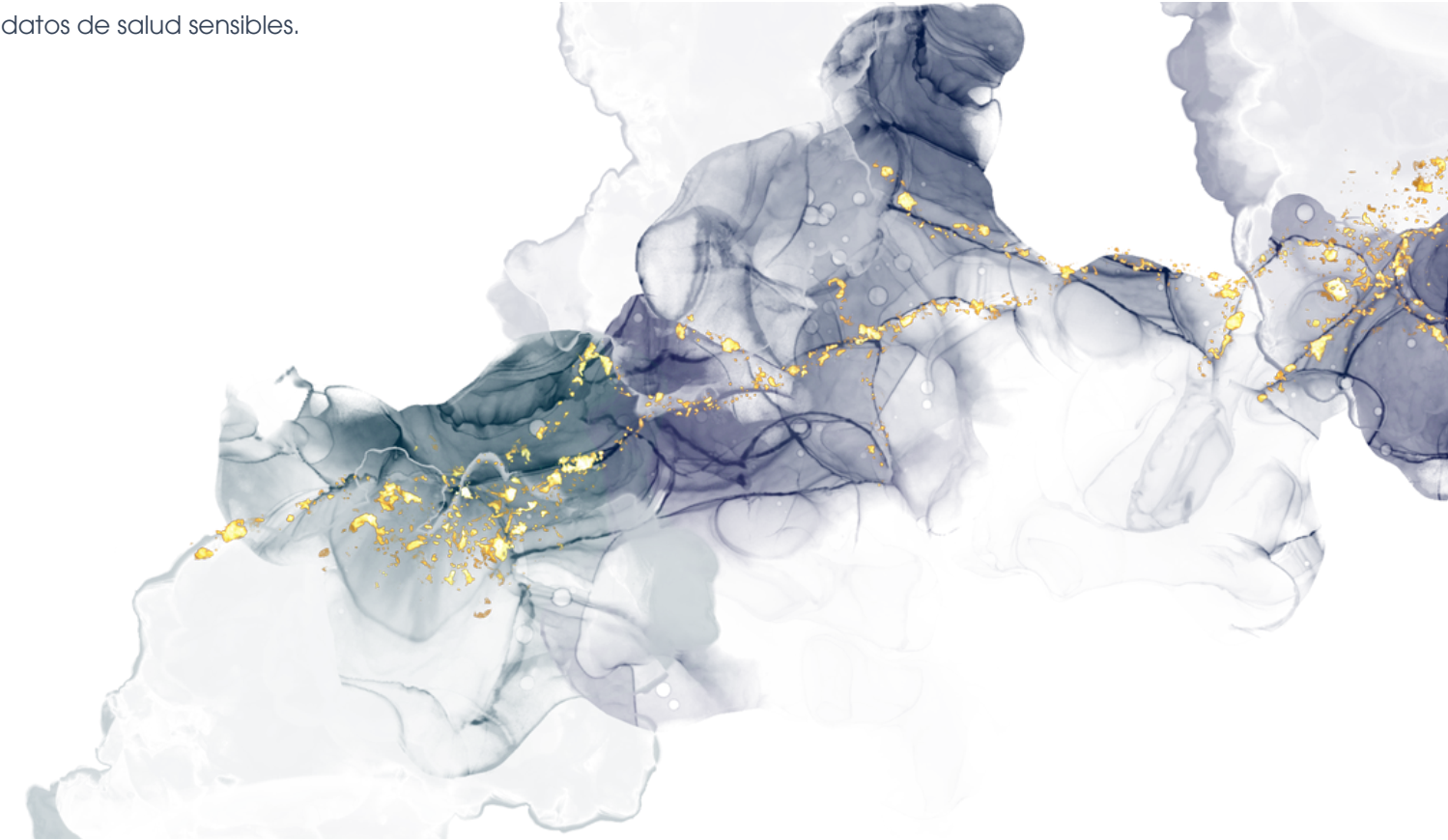
CWE	CWE-639 — Authorization Bypass Through User-Controlled Key
OWASP Top 10	A01:2021 — Broken Access Control
Vector CVSS 3.1	AV:N / AC:L / PR:L / UI:N / S:U / C:H / I:H / A:L
Estado	Abierto

Descripción técnica

El sistema expone dos endpoints de turnos: uno de lectura (/api/<id>/appointments/) y uno de borrado (/api/appointments/<id>/), ambos identificados por un ID numérico que no se valida contra la sesión activa. Cualquier usuario autenticado puede modificar ese ID (probado con Burp Suite) y acceder o eliminar turnos médicos ajenos.

Impacto

Un atacante con una cuenta común puede leer la agenda médica completa de cualquier paciente y cancelar sus turnos sin su consentimiento, afectando la operatoria del centro de salud y la confidencialidad de datos de salud sensibles.



Prueba de Concepto (PoC) — Paso a Paso

Reproducción completa del hallazgo en el entorno de laboratorio. Cada paso es reproducible y verificable.

- 1 Iniciar sesión con un usuario común («luis») e interceptar con Burp Suite el GET a «Mis Turnos».
- 2 La petición dispara GET /api/<id>/appointments/, donde <id> es el ID del usuario autenticado.
- 3 Modificar manualmente ese <id>. Al llegar al valor 101, el servidor devuelve los turnos de otro usuario («xdalvik»): 4 turnos con IDs 10, 11, 12 y 13.
- 4 Interceptar la acción «Cancelar» de un turno propio: dispara DELETE a /api/appointments/<id>/.
- 5 Reemplazar ese <id> por cada uno de los 4 IDs ajenos (10, 11, 12, 13) y reenviar el DELETE.
- 6 **El servidor responde «Turno eliminado correctamente» en los 4 casos, sin validar ownership → los turnos de «xdalvik» quedan eliminados sin su consentimiento.**

```
GET /api/101/appointments/ HTTP/1.1
Host: turnero-lab.local
Cookie: session=<sesión de luis>

--- Respuesta: turnos de otro usuario ---
HTTP/1.1 200 OK
[{"id":10},{"id":11},{"id":12},{"id":13}]

--- DELETE /api/appointments/10/ ---
HTTP/1.1 200 OK
{"mensaje":"Turno eliminado correctamente"}
```

Evidencias

Evidencia completa del hallazgo en el entorno de laboratorio.

The screenshot displays a web application interface titled "Mis Turnos" (My Appointments) and a corresponding network traffic capture in Chrome DevTools.

Web Application Interface:

The "Mis Turnos" page shows a table of appointments:

Fecha y Hora	Especialista	Clínica	Acciones
20/9/2026, 04:15:41	Lic. Lopez	Clínica privada	Cancelar
19/9/2026, 10:15:41	Dr. Lange	Punilla	Cancelar
20/9/2026, 06:15:41	Dra. Farias	Hospital N° 14	Cancelar

Network Traffic Capture:

The network tab in Chrome DevTools shows a series of requests to the API endpoint `/api/101/appointments/`. The selected request is a `DELETE` request with a status of 200. The response body is a JSON object:

```
{ "message": "Turno eliminado correctamente" }
```

The "Headers" tab shows the request headers, including `Host`, `Accept-Encoding`, `Referer`, `Connection`, `Cookie`, `Sec-Fetch-Dest`, `Sec-Fetch-Mode`, `Sec-Fetch-Site`, `TI`, `User-Agent`, `Accept`, `Accept-Language`, and `Priority`.

6. Conclusiones y Plan de Remediación Recomendado

Se recomienda priorizar la corrección del hallazgo Alto antes del pase a producción. A continuación, la corrección técnica y el plan de verificación.

Corrección recomendada — Validar la propiedad del recurso en el backend

```
// middleware/validateOwnership.js
function validateOwnership(req, res, next) {
  const userId = req.session.userId;
  const { id } = req.params;
  if (!belongsToUser(id, userId))
    return res.status(403).json({ error: "Acceso denegado" });
  next();
}
// Se aplica en GET /api/:id/appointments/
// y en DELETE /api/appointments/:id/
```

Plan de acción y timeline

INMEDIATO (0-24 h)

Deshabilitar temporalmente el borrado vía API o restringir el acceso hasta aplicar el fix.

CORTO PLAZO (1-3 d)

Implementar la validación de propiedad del recurso en ambos endpoints (ver código).

VERIFICACIÓN (3-5 d)

Ejecutar el re-test del hallazgo y cerrar formalmente el ticket.

Criterios de verificación (re-test)

- Un usuario no puede leer ni cancelar turnos que no le pertenecen (respuesta 403).
- El identificador de turno/usuario se valida contra el dueño real de la sesión.
- Los endpoints de lectura y borrado aplican la misma validación de ownership.

Elaborado por

María de los Ángeles Acuña
QA Tester

Revisado y aprobado por

Lead Security Auditor / CISO
Firma: _____

